Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-16 09:00 WIB

Top 5 Highlights

- Global law enforcement disrupts massive phishing-as-a-service ecosystem
- AI-Powered Espionage Campaign Targets Government Linux Infrastructure
- F-Secure Launches Victim-First Scam Encyclopedia Covering 50+ Types of Consumer Fraud
- Hackers exploit Collabora RCE flaw to backdoor Nextcloud servers
- Critical PwnEscape Linux Kernel Vulnerability Lets Guest VMs Read Host Memory

Threat Intelligence (10)

01. AI-Powered Espionage Campaign Targets Government Linux Infrastructure

Our analysis an AI-powered espionage campaign targeting government Linux infrastructure with custom malware, web shells, and advanced credential theft. The post AI-Powered Espionage Campaign Targets Government Linux Infrastructure appeared first on Unit 42 .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://unit42.paloaltonetworks.com/ai-campaign-targets-linux-infrastructure/

02. Fake Arch Linux packages push malware with root privileges

A threat actor uploaded malicious packages to the Arch User Repository (AUR) that impersonated two popular helper tools, yay and paru. […]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/fake-arch-linux-packages-push-malware-with-root-privileges/

03. KGB RAT trojan packs webcam spying, password theft and a “fun” menu to terrorize victims

A Windows trojan advertised on hacking forums for as little as $150 a month promises buyers access to a victim’s webcam, microphone, keystrokes and saved passwords, and comes with a set of features made to frighten the person on the other side of the screen. The malware, called KGB RAT, was analyzed by Group-IB malware analysts Alpomish Asadov and Razvan Ra…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.helpnetsecurity.com/2026/10/15/kgb-rat-windows-trojan-webcam-spying-password-theft/

04. Fake CAPTCHAs are tricking users into running malware on their own devices

Fake CAPTCHA checks are being used to do more than hide phishing pages. Attackers are turning the familiar “prove you’re human” step into a gateway for malware downloads, malicious browser notifications, and commands that victims are tricked into running themselves, according to Barracuda. The company found CAPTCHA abuse in 43% of the phishing-kit attacks i…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.helpnetsecurity.com/2026/10/15/barracuda-fake-captcha-phishing-attacks/

05. New Aoki Infostealer Targets AI Coding Assistant Credentials

Symantec warned that Aoki can steal API keys and tokens from a number of popular AI coding assistants, including Claude and Gemini

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.infosecurity-magazine.com/news/aoki-infostealer-ai-coding/

06. Is this link safe? Find out with Malwarebytes Scam Link Check

Not sure if a link is safe? Malwarebytes Scam Link Check scans suspicious links for signs of phishing, scams, malware, and other online threats before you click.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.malwarebytes.com/blog/product/2026/10/is-this-link-safe-find-out-with-malwarebytes-scam-link-check

07. Fake AI Attacks Spread Across US Companies: How MSSPs Can Stop Incidents Early

Attackers are impersonating popular AI products to distribute malware, steal browser sessions, and compromise business accounts. ANY.RUN linked 1,258 public sandbox analyses to fake AI campaigns between April and October of 2026. The campaigns also increase operational pressure on MSSPs serving US businesses, which accounted for 16% of country-attributed ta…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/fake-ai-attacks-spread-across-us.html

08. CikaBika Bot RAT Uses Discord for C&C

Delivered via phishing, the malware provides reconnaissance, remote execution, and data exfiltration capabilities. The post CikaBika Bot RAT Uses Discord for C&C appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.securityweek.com/cikabika-bot-rat-uses-discord-for-cc/

09. Novel Android RAT ‘Hirudo’ Replaces Banking Apps With Trojanized Copies

The Hirudo malware combines elements of a traditional banking trojan and a full-featured RAT. The post Novel Android RAT ‘Hirudo’ Replaces Banking Apps With Trojanized Copies appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.securityweek.com/novel-android-banking-rat-hirudo-replaces-banking-apps-with-trojanized-copies/

10. Microsoft Disrupts Global Yam Store Network Behind One Billion Phishing Messages

Microsoft and partners reveal a major Chinese-language phishing network centered around the Yam Store marketplace

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.infosecurity-magazine.com/news/microsoft-yam-store-one-billion/

Latest Vulnerabilities (10)

01. Global law enforcement disrupts massive phishing-as-a-service ecosystem

A significant cybercriminal operation, responsible for over a billion malicious messages and targeting more than 75,000 organizations globally, has been dismantled by international law enforcement agencies and partners.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/global-law-enforcement-disrupts-massive-phishing-as-a-service-ecosystem

02. Hackers exploit Collabora RCE flaw to backdoor Nextcloud servers

Threat actors are exploiting a critical command execution flaw, now tracked as CVE-2026-110447, in the Collabora Online - Built-in CODE Server app

(richdocumentscode) for Nextcloud. […]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/hackers-exploit-collabora-rce-flaw-to-backdoor-nextcloud-servers/

03. Critical PwnEscape Linux Kernel Vulnerability Lets Guest VMs Read Host Memory

A newly disclosed critical flaw in the Linux kernel allows code inside a virtual machine to read memory on the host computer it runs on. A researcher demonstrated the leak against Vercel's live cloud sandboxes, and Vercel confirmed it. The flaw, now tracked as CVE-2026-99999 and nicknamed PwnEscape, is in the Linux kernel's networking code, not in any one c…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://thehackernews.com/2026/10/critical-pwnescape-linux-kernel.html

04. Vulnerability in Nextcloud app allowed attackers to plant web shells

Attackers exploited a flaw in an optional Nextcloud app, Collabora Online - Built-in CODE Server, to plant web shells on Nextcloud servers.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/vulnerability-in-nextcloud-app-allowed-attackers-to-plant-web-shells

05. Large companies more likely to leave critical vulnerabilities unpatched, study finds

Large companies with over $1 billion in revenue are more than twice as likely to knowingly leave high or critical vulnerabilities unpatched compared to smaller businesses.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/large-companies-more-likely-to-leave-critical-vulnerabilities-unpatched-study-finds

06. ThreatsDay: Adobe RCE, DNS Wallet Theft, NVIDIA Container Escape, Self-Healing Backdoor + 23 More

Someone built a tool to steal data, then decided it should scare the victim for fun. Yes, that’s an actual feature. And somehow, it fits right in with this week's security stories. The rest gets interesting in different ways. A small permission can lead to a big theft. A trusted login can hide the wrong person. Old bugs are finding new victims, familiar too…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://thehackernews.com/2026/10/threatsday-adobe-rce-dns-wallet-theft.html

07. AWS Security Agent (now part of AWS Continuum) exploited 33 of 37 new real-world CVEs

We applied AWS Security Agent (now part of AWS Continuum), our autonomous penetration-testing agent, to 37 real, recently disclosed Common Vulnerabilities and Exposures (CVEs), each packaged as a live, containerized target with a flag hidden at the vulnerability’s intended sink. Starting from an unauthenticated or low-privilege position (an endpoint URL and…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://aws.amazon.com/blogs/security/aws-security-agent-now-part-of-aws-continuum-exploited-33-of-37-new-real-world-cves/

08. Silent Lynx Exploits WinRAR Flaw to Deploy Reverse Shell in CIS Government Attacks

The threat actor known as Silent Lynx has been attributed to a fresh set of attacks targeting government organizations across the Commonwealth of Independent States (CIS). The activity, observed from June 2025 through August 2026, involves four different infection chains that make use of macro-enabled documents, PS2EXE downloaders, GitHub-hosted PowerShell,…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://thehackernews.com/2026/10/silent-lynx-exploits-winrar-flaw-to.html

09. Vulnerability Management Isn't About the Score - It's About How It Applies to You

Organizations need to move away from vendor-assigned, theoretical scores toward real exploit data specific to their environments.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.darkreading.com/cybersecurity-operations/vulnerability-management-isnt-about-the-score-its-about-how-it-applies-to-you

10. Bank of America had to bring in 1,000 contractors to patch all the bugs Mythos identified

CEO said the workers were hired in Q2 and are still helping today

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.theregister.com/security/2026/10/15/bank-of-america-had-to-bring-in-1000-contractors-to-patch-all-the-bugs-mythos-identified/5303275

Data Breach & Cybercrime (10)

01. F-Secure Launches Victim-First Scam Encyclopedia Covering 50+ Types of Consumer Fraud

Built from decades of threat intelligence research, the new resource explains scams from the victims' perspective and tracks emerging forms of cyber crime.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.darkreading.com/threat-intelligence/f-secure-launches-victim-first-scam-encyclopedia-covering-50-types-of-consumer-fraud

02. North Macedonia charges alleged administrator of OLVX cybercrime marketplace

Authorities in North Macedonia have filed charges against the alleged administrator of OLVX, a cybercrime marketplace that sold stolen personal data and malicious tools since 2023.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/north-macedonia-charges-alleged-administrator-of-olvx-cybercrime-marketplace

03. Android gets AI defenses against messaging scams, fake calls

Google announced new AI-powered defenses against scam messages and call-forwarding abuse on Android, currently rolling out to eligible devices. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/android-gets-ai-defenses-against-messaging-scams-fake-calls/

04. Australian startup Apate uses AI agents to bait scammers

Apate.ai, an Australian startup founded in 2024, deploys thousands of AI agents to pose as potential victims and engage with scammers.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/australian-startup-apate-uses-ai-agents-to-bait-scammers

05. Hackers hijack D-Link, Ubiquiti devices to resell your stolen bandwidth

A proxyjacking campaign has impacted devices in 34 countries, monetizing victims' internet connections through a commercial residential proxy network. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/hackers-hijack-d-link-ubiquiti-devices-to-resell-your-stolen-bandwidth/

06. Help TDS Linked to Hotejka as 20,000+ Cloudflare Pages Domains Host Tech Support Scams

A long-running Traffic Distribution System (TDS) known as Help TDS to a Russian-language affiliate program called Hotejka, which appears to be a rebrand of a traffic monetization operation dubbed ROI777. Help TDS is assessed to be active since at least 2017, offering PHP code templates to partners and affiliates that are installed into compromised websites...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/10/help-tds-linked-to-hotejka-as-20000.html

07. Ransomware extortion gets personal as attackers target employees’ families

Ransomware attackers are expanding their tactics beyond encrypting corporate systems and threatening to leak stolen data. They are increasingly using AI in attacks, exploiting organizations’ own AI systems and even using physical intimidation by threatening employees and their families to pressure companies into paying ransoms. The Semperis’ 2026 Ransomware…

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.csoonline.com/article/4235782/ransomware-extortion-gets-personal-as-attackers-target-employees-families.html

08. Legal Aid Agency hackers made off with records dating back to 1978

Nearly 50 years of data caught up in breach, with probation service records also among the haul

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.theregister.com/security/2026/10/15/legal-aid-agency-hackers-made-off-with-records-dating-back-to-1978/5303243

09. India Mandates Registered Caller Name Display on 4G and Newer Networks From November 1

The Indian government has directed telecom service providers (TSPs) in the country to mandatorily display callers' registered names along with their numbers for incoming calls starting November 1, 2026, in an effort to help people identify calls from unknown numbers and tackle spam or fraudulent calls. To that end, the Department of Telecommunications has i…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/10/india-mandates-registered-caller-name.html

10. [+24h Old] CenterPoint Energy Data Breach Impacts 1 Million Texans

Personal information such as names, addresses, Social Security numbers, and driver’s license numbers was compromised. The post CenterPoint Energy Data Breach Impacts 1 Million Texans appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.securityweek.com/centerpoint-energy-data-breach-impacts-1-million-texans/